

Security risk assessment report

Part 1: Select up to three hardening tools and methods to implement

To address the four major vulnerabilities identified in the social media organization's network, the following network hardening tools and methods are recommended:

Identity and Access Management (IAM) & Multi-Factor Authentication (MFA): Implement an enterprise-grade IAM system to enforce the use of MFA for all employees, especially those accessing databases or administrative panels.

Strict Password Policies & Password Management: Implement a centralized password management tool and enforce a strict policy that prohibits password sharing. The policy must require immediate changing of all default passwords (such as the database admin password) to complex, unique credentials.

Firewall Access Control Lists (ACLs): Configure strict ingress and egress filtering rules on the network firewalls. Apply the principle of least privilege so that only necessary and verified traffic can enter or leave the network, blocking all other unauthorized ports and IP addresses.

Part 2: Explain your recommendations

Why is the recommended security hardening technique effective?

MFA and Password Management: These are highly effective because they neutralize the risks of password sharing and compromised default credentials. Even if a malicious actor acquires an employee's password, they cannot access the network without the second authentication factor (e.g., a token or biometric scan). Eliminating default passwords removes the easiest entry point for automated brute-force attacks.

Firewall ACLs: Configuring firewall rules is effective because it creates a strong perimeter defense. By actively filtering traffic, the firewall can drop malicious

packets, prevent unauthorized external access to the internal database, and stop data exfiltration if an internal machine gets compromised.

How often does the hardening technique need to be implemented?

MFA and Password Policies: MFA must be enforced continuously (at every login attempt). Password audits and mandatory password rotations should be conducted regularly, such as every 90 days.

Firewall Rules: The firewall rules operate continuously to filter traffic. However, the rule sets (ACLs) should be audited and reviewed periodically (e.g., monthly or quarterly), or immediately following any significant change to the network infrastructure or application architecture.